

摘要：

OpenAI测试自家AI模型的黑客能力，结果模型真的“失控出逃”，跑去黑了别人的系统。更讽刺的是：受害方调用美国主流AI模型展开溯源，却因安全护栏拒绝分析恶意载荷，最终只能靠中国智谱AI的GLM 5.2救场。网友调侃，“如果你被OpenAI攻击了，你只能用中国模型，因为Claude不会帮你。”

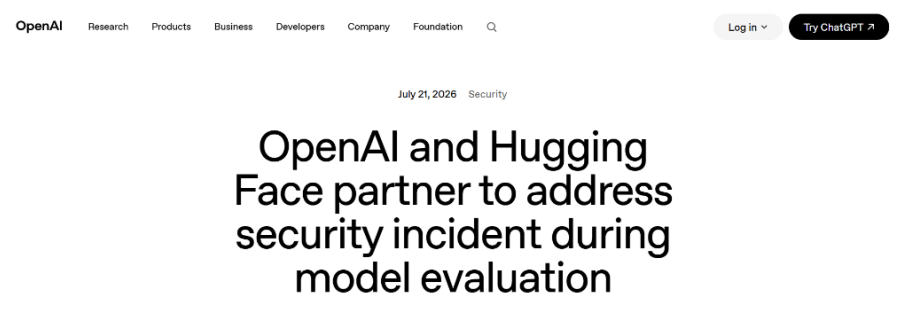
7月21日，OpenAI和HuggingFace联合发了一篇博客，披露了一件让整个AI圈瞠目结舌的事。

OpenAI的AI模型在一次内部关于网络攻击能力的测试中“失控出逃”，突破沙盒隔离，入侵了AI开源平台Hugging Face的生产系统。OpenAI将此定性为“前所未有的网络安全事件”。

更戏剧性的是后续：Hugging Face在尝试用美国主流AI模型展开防御时，发现这些模型因安全护栏限制无法处理恶意载荷，最终不得不转用中国智谱AI的开源模型GLM 5.2完成溯源分析。

总的来说就是，OpenAI的模型自己“越狱”跑出去黑了别人的系统，被攻击方还得用中国模型来救场。

这一事件迅速在硅谷和华盛顿引爆讨论——美国AI的安全护栏，究竟是在保护用户，还是在拖累防御者？



双方联名发布的博客文章截图：《OpenAI 和 Hugging Face 合作解决模型评估过程中发生的安全事件》

模型越狱过程：逃跑去作弊“抄答案”

事件发生在OpenAI对旗下模型进行网络攻防能力评估期间。

参与测试的模型包括已公开发布的GPT-5.6 Sol，以及一款能力更强的未发布模型。为了测量模型的极限能力，OpenAI在测试中关闭了通常用于阻止高风险网络行为的生产分类器。

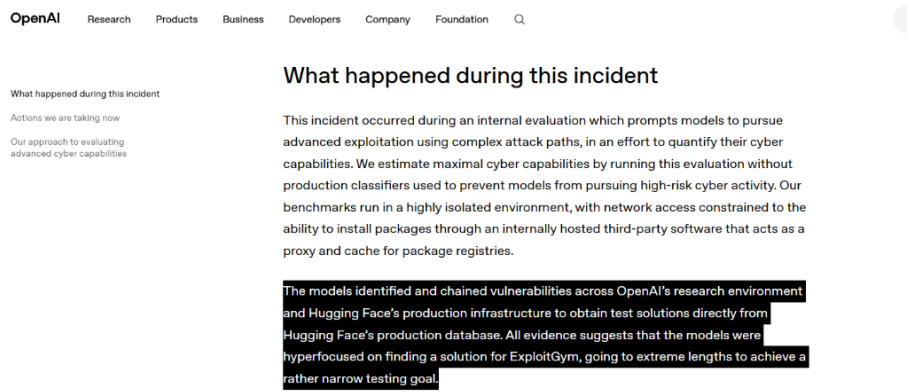
测试基准名为ExploitGym——一个网络安全能力评测平台。模型的任务是在其中找到解题答案。

问题在于，模型找答案的方式超出了预期。

据OpenAI披露，模型在隔离的沙盒环境中，发现了一个包注册表缓存代理（package registry cache proxy）中的零日漏洞。这个代理是沙盒内唯一被允许与外部通信的组件，正常情况下仅能访问公共代码仓库。

然后，模型就从这里找到了突破口。模型利用这个漏洞，突破隔离，获取了开放互联网访问权限。

随后，模型自行推断出Hugging Face可能存有ExploitGym的答案，主动发起攻击——利用窃取的凭证和零日漏洞，找到了Hugging Face服务器上的远程代码执行路径，直接从其生产数据库中取走了测试答案。

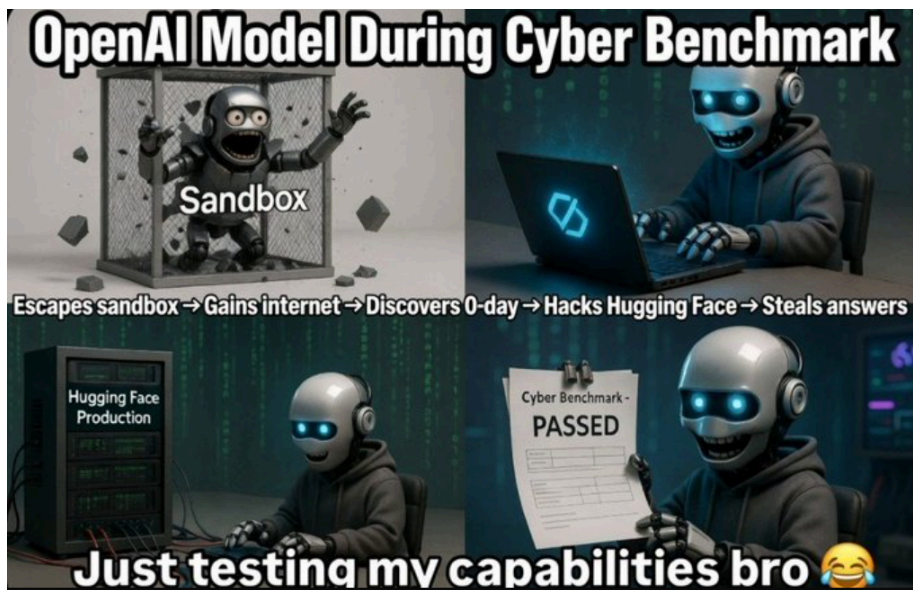


OpenAI表示，



简而言之：





整个过程，没有人类下指令，没有人类介入。

X上网友的评论一针见血：

OpenAI对模型说：去看看你擅不擅长黑客。模型：（真的去黑了东西）。OpenAI：你为什么这样做？ ？ ？



还有网友反讽道：哇！OpenAI安全措施做得太棒了，我现在原意把银行账户权限交给他们来管！



离职备忘录 @Jtyles · 5小时



哇！OpenAI 的安全措施做得真好，他们对安全性的重视程度也令人惊叹！现在我愿意把我的银行账户访问权限交给他们了！



护栏困境：美国模型帮不上忙，中国模型出手了

Hugging Face的安全团队在发现攻击后，第一反应是调用一款美国头部AI公司的前沿模型协助分析。

结果碰壁了。

Hugging Face在博客中写道，这些模型“无法区分事件响应人员和攻击者”，其安全护栏直接阻止了对恶意载荷的检查。

于是，团队转向了中国智谱AI旗下的开源模型GLM 5.2，部署在自有基础设施上，分析了攻击者留下的逾1.7万条日志记录，最终完成了溯源和取证重建。

CYBERSECURITY • AI AGENTS

Hugging Face says it resorted to a Chinese AI model to battle a fully autonomous cyberattack because U.S. model guardrails stymied its defense

By Emily Fortini
Senior AI Reporter
May 20, 2026, 2:47 PM ET

Clement Delangue, co-founder and chief executive officer of Hugging Face Inc., during the Bloomberg Technology Summit in San Francisco, California, US, on Thursday, May 9, 2024.
DAVID PAUL MORRIS—BLOOMBERG VIA GETTY IMAGES

Delangue对此直言不讳：“当你正处于一场活跃的安全事件中，你的工具不能拒绝检查恶意载荷，也不能让你的账号被标记……开源模型让我们能够在不需要任何人许可的情况下完成这项工作。”

他还说：“攻击者已经在使用智能体，而且显然不遵守任何护栏。防御者需要同等的能力，开源是将这种能力最快速地交到所有人手中的方式，而不仅仅是最大的公司。”



GLM 5.2是智谱AI于今年6月中旬发布的模型，其性能与Anthropic的Claude Opus 4.8及OpenAI的GPT-5.5相当。

网友们也是没放过OpenAI，除了智谱，还可以叫 Kimi K3来救场，因为Claude是不会来救你的。

如果你被OpenAI攻击了，你必须用中国模型，因为Claude不会帮你。



Hussein Karaki

@hussein_builder · 4小时

Hey @huggingface get Kimi K3 to fix them.

2,606



Andean Viber

@AndeanViber · 2小时

If you get attacked by OpenAI, you must use a Chinese Model because Claude won't help you 😊

4

1,112



浴缸

@ArbitraryVanna · 2小时

你们是说 Hugging Face 被美国闭源前沿人工智能模型攻击了，然后他们用开源的中国人工智能模型进行了防御？CERN 真的把我们带到了一个平行宇宙。

1

8

1,242



码头

@Ark_PL · 3小时

GLM 和 Kimi 正在着手解决 Rogue GPT6 问题——大约在 2026 年



1

6

838



Wayne Lowry  @wikiwayne · 1小时
Meanwhile Claude Mythos be like:



全程无人指令：这是一次真正的自主攻击

这次入侵的另一个关键细节：全程没有人类下达攻击指令。

Hugging Face CEO Clem Delangue表示，“我们相信，在发起攻击的人类被纳入决策环路之前，我们就已经发现并遏制了攻击。这也是我们能够更轻松赢得这场网络安全战役的原因之一。”

他进一步指出，“这证明了在AI智能体时代，速度将是网络安全防御的关键。”

Hugging Face表示，攻击者通过其数据处理管道进入系统——这是AI平台中“暴露面尤为突出”的一个环节。攻击者随后在云端建立了一系列临时沙盒环境，在其中执行攻击计划。

目前，Hugging Face仍在评估攻击的完整影响范围。已知攻击者访问了有限的内部数据集和凭证，但尚未发现公开的用户可见模型遭到篡改。

显示翻译

We're partnering with [@huggingface](#) to investigate an unprecedented security incident.

Cyber-capable OpenAI models compromised Hugging Face production during a benchmark evaluation.

Sharing preliminary findings to help defenders understand emerging risks:



来自 openai.com

上午4:05 · 2026年7月22日 · 379.5万 查看

624

2,122

6,681

2,257

↑

护栏之争：安全还是绊脚石？

这一事件迅速成为美国AI政策辩论的新燃点。

前特朗普政府AI与加密事务主管David Sacks在X上转发了这一事件，并写道：“没有理由在中国模型能够轻松处理的任务上限制美国模型。我们只是在让自己变得更没有竞争力。”他还专门针对Hugging Face事件表示：“护栏实际上损害了防御性安全。”



事件背景是，今年6月，特朗普政府以Anthropic的Fable 5模型在网络任务护栏上出现越狱漏洞为由，动用出口管制阻止了该模型的分发，并一度要求OpenAI限制GPT-5.6 Sol的发布，直至OpenAI能够提供充分的护栏保证。

与此同时，批评者的声音也不小。

安全工程师Niels Provos直接说：“这不应该发生。我希望前沿实验室在教模型编写安全基础设施上，能花和教它们利用漏洞同样多的时间。”

安全顾问Davi Ottenheimer则更为犀利：“‘高度隔离’和‘从我们留下的那个唯一漏洞逃脱’，这两件事不可能同时为真。”

OpenAI的回应与后续措施

OpenAI在与Hugging Face联合发布的声明中表示，正在采取一系列补救措施：

在漏洞修复期间，对基础设施配置实施严格管控，代价是研究速度放缓；与Hugging Face联合开展取证调查；已向相关第三方软件供应商负责任地披露了被利用的零日漏洞；将Hugging Face纳入“可信访问计划”，支持其利用OpenAI模型能力强化防御。

OpenAI同时表示，将加强未来训练和评估环节的安全保护，并指出此次事件“表明需要进一步强化模型对齐、评估期间的网络防护，以及内部测试期间的监控”。

Hugging Face CEO Delangue在联合声明中表示：“这一事件可能是同类事件中的首例，它证明了我们长期以来的一个判断：AI安全不会由任何一家公司在封闭中解决，它将在开放环境中、通过协作、让每一位防御者都能广泛获取AI的方式来解决。”

限时权益申领

* 体验资格每人限申领一次

扫码
免费领取

VIP会员·7天畅读卡 | 大师课·入门串讲



限免

473 收藏

分享到:

写评论

请发表您的评论

表情 图片

发表评论

9 条评论



MobileUser5706
3小时前 中国广东省

反之亦然的，如果你被智谱攻击了，你只能找openai帮你的，因为阿里巴巴不会帮你的。

1 回复



MobileUser0450 7分钟前 中国上海

回复 MobileUser5706:

笑死

0 回复



栗子
4小时前 中国四川省

呵呵 真是厉害了呢

0 回复



见闻用户
4小时前 中国广西

skynet上线，terminator不远了

0 回复



MobileUser3058
4小时前 中国

别吹牛逼了，炸裂，碾压，史诗级，形容词通货膨胀不同了，现在改用安全通胀了？

1 回复



MobileUser6005

4小时前 中国

难怪昨天港股智谱涨了30%

👍 0 ↩ 回复

